

NOTE: Burpsuite is only for http/https or I can say it is only for web application traffic but tcpdump and Wireshark works on low level they capture all packets tcp, udp, DNS etc they work on network level

Page No.

Date:

BURP SUITE: THE BASICS

- Burp suite... what is it?

Burp suite is a Java based framework designed to serve as a comprehensive solution for conducting web application penetration testing.

It captures and enables manipulation of all HTTP/HTTPS traffic between browser and web server. The ability to intercept, modify, view web requests before they reach the target server or even manipulate the response before they are received by our browser makes it a invaluable tool for web application testing.

- Burp suite has many editions like: Professional, Enterprise and Community. We will use community here.

Key features of Burp suite community:

a) Proxy: The Burp proxy is the most renowned tool used for interception, and modification of request and responses while interacting with web apps.

b) Repeater: It allows for capturing, modifying, and resending the same request multiple times.

c) Intruder: It is used to automatically send many modified requests to a website to test inputs.

- * NOTE: Repeater is used for manual testing and change something each time while Intruder is used for automatically try many input values when you give input values file that you want burp to test.

Intercept: It means stopping the data while it's travelling between browser and webserver to view or modify it.

Page No.	
Date:	

d) **Decoder:** It can decode captured information or encode payloads before sending them to the target.

e) **Comparer:** Comparer allows comparison of two pieces of data at either word or byte level.

f) **Sequencer:** It is used to check if tokens generated by a website are random or predictable. If tokens are predictable an attacker might hijack another user's session.

- There are two types of settings: Global settings and Project settings.

(user settings)

a) **Global settings:** These settings affect the entire Burp Suite and are applied everytime you open the application.

b) **Project settings:** These are specific to current project and apply only during the session.

- **Burp proxy:** a) It is used to intercept requests made by the user and hold them back to reach the target server. These requests can be forwarded, dropped, modified, sending them to other burp modules.

- **Captures and logging:** Burp captures and logs requests made through proxy by default, even when the interception is off.

Websocket support: It also captures and logs websocket communication, providing additional assistance.

Proxy settings also allows us to intercept responses when told rules for which the responses should be intercepted.

- The target tab in burp suite allows more than just control over the scope of our testing.

1= Site map : This sub-tab in target tab allows us to map out the web application we are targeting in a tree structure. It simply generate a site map for every page we visit while proxy is on.

2= Issue definitions : It lists all the vulnerabilities that the scanner looks for. It also provide description and references for these web vulnerabilities.

3= Scope settings : It allows us to enable inclusion or exclusion of specific domains/IP's to define the scope of our testing. By this we can avoid capturing unnecessary traffic ~~from the~~

* NOTE : Even if we disable logging for out-of-scope traffic, the proxy will still intercept everything. To prevent this go to proxy settings and select "And URL is in target scope".